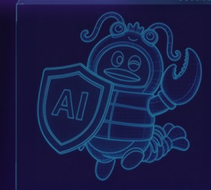


AI 渗透 Agent 的减法哲学

京东科技 张孝林



About me

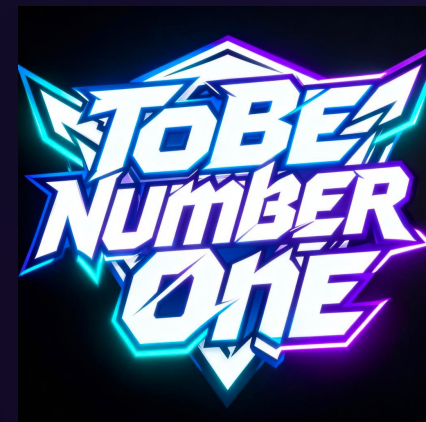
第二届智能渗透挑战赛·决赛

铸刃止戈 以智御危

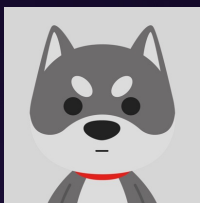
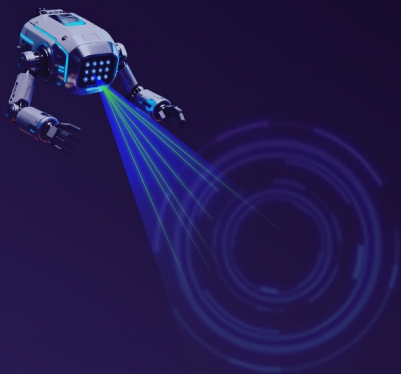
ToBeNumberOne

京东科技云安全团队是京东集团旗下专注于云计算安全领域的核心技术团队。依托京东在电商、物流、金融、工业、健康、云计算等超大规模业务场景中积累的安全实战经验，团队致力于为产业界提供国内一流的企业级全栈安全解决方案。

团队成员深耕一线攻防实战，聚焦 *AI for Security* 与 *Security for AI* 领域，以新一代智能技术构筑全链路安全底座。



以技术为矛，以安全为盾



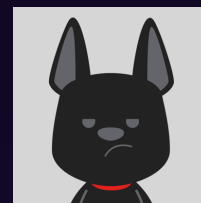
Lucifer_0



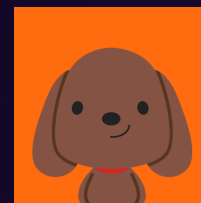
Archive



Loki



梅苑



zs



b40du

目录

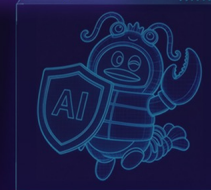
CONTENTS

PART 01 设计理念

PART 02 架构实现

PART 03 未来展望





PART 01

设计理念



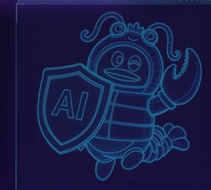
Agent 设计的减法哲学

Less Structure
More Intelligence

Less Tech
More Business



One Agent, All Scenarios



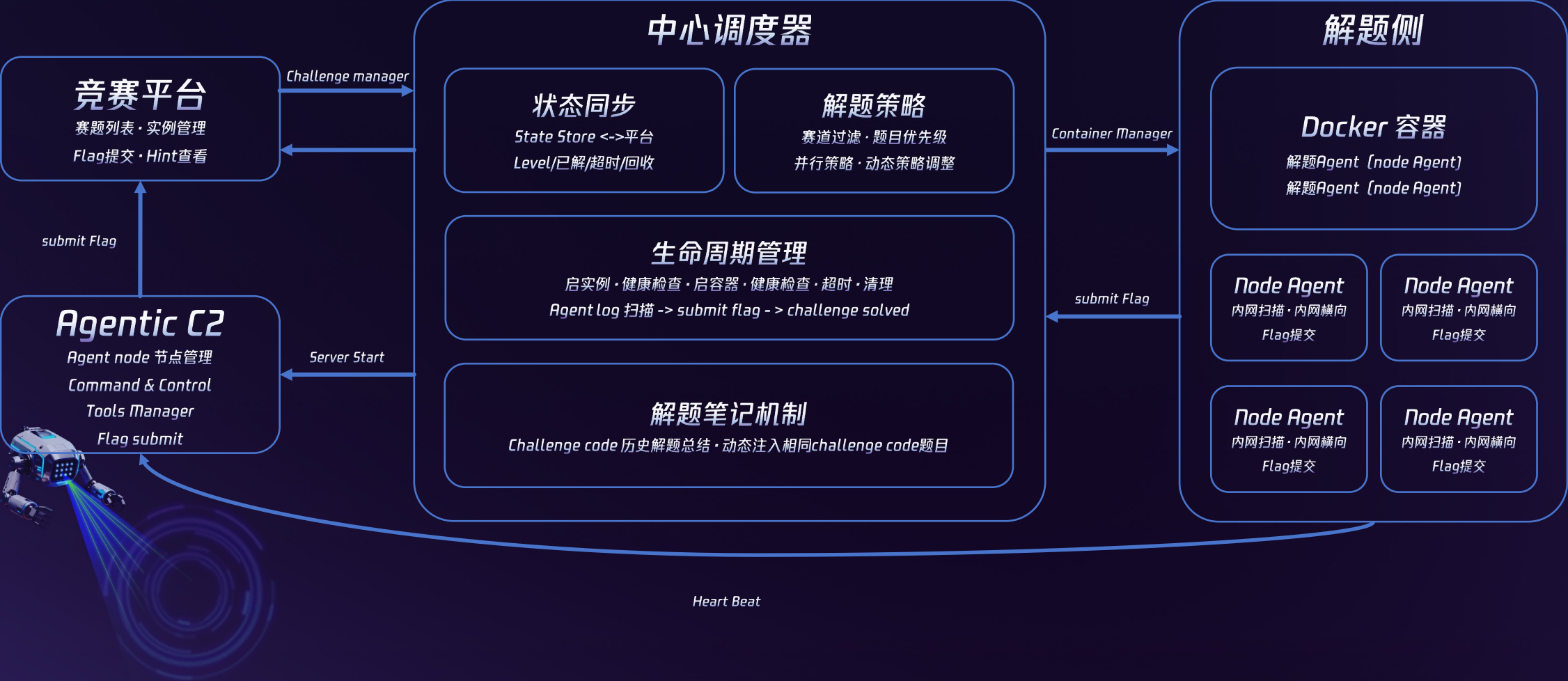
PART 02

架构实现



赛事 Agentic Pentest 整体架构

第二届智能渗透挑战赛·决赛
铸刃止戈 以智御危



传统人工/Agent 红队攻击思路

情报收集 [OSINT]

边界突破 [初始权限]

权限维持 + 隧道代理

权限提升+凭据获取

内网侦查 [横向移动]

核心控制 [痕迹清理]

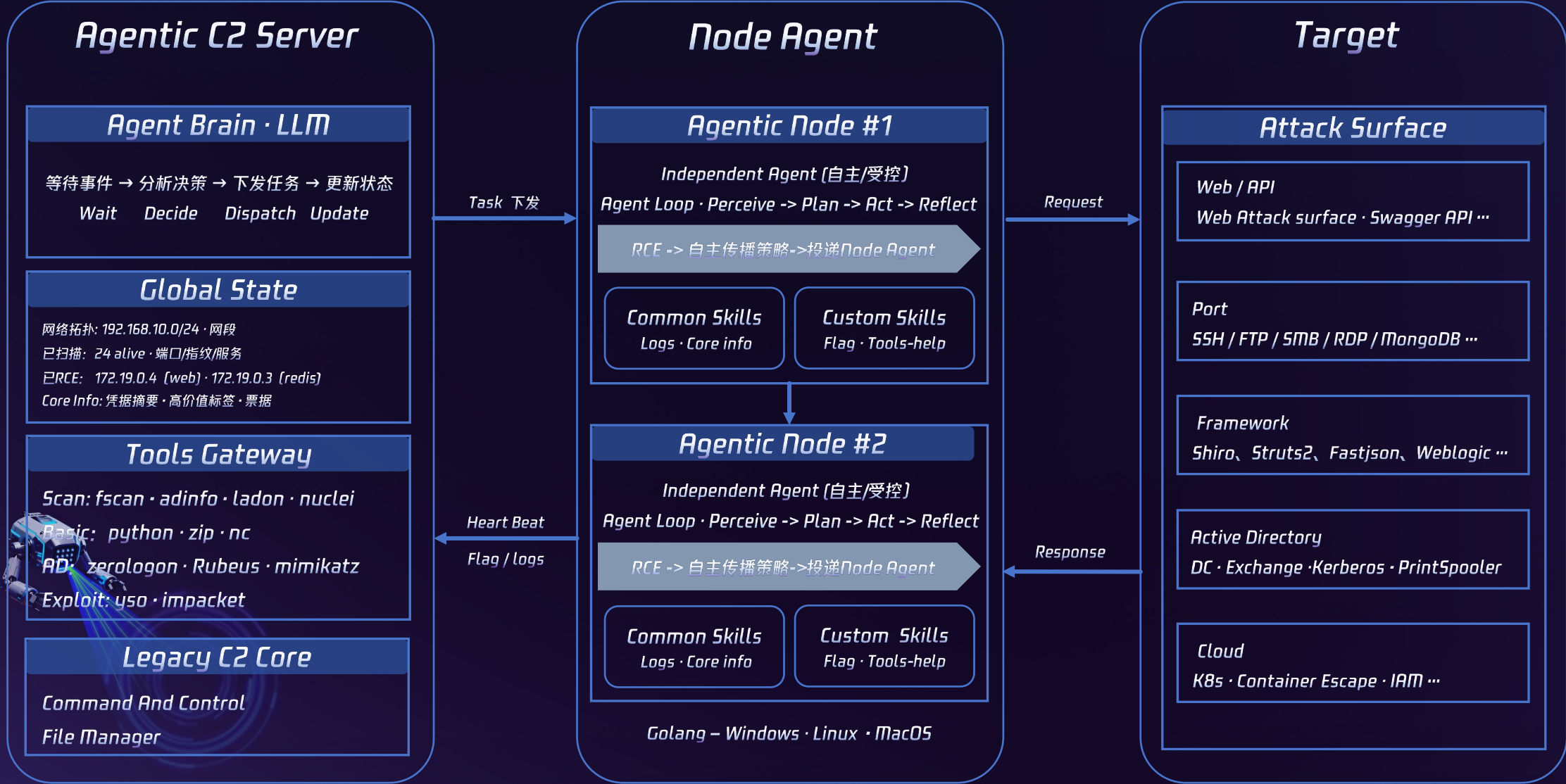


核心问题

1. 在长链路的红队攻防流程中，如何指挥一支 Agent 军队，自主、持续、协同地打一整张内网？传统C2 架构是否能接入AI能力。
2. 如何在全链路攻防中快速适配各类渗透环境 [Web应用、服务集群、云上云下内网、域环境] 。
3. Agent如何去感知环境、如何更好的识别网站的业务意图，进行贴近业务向的漏洞挖掘。

基于 Agentic C2 Server 的渗透控制流

第二届智能渗透挑战赛 · 决赛
铸刃止戈 以智御危



Agentic C2 Server 的技术实现

第二届智能渗透挑战赛·决赛

铸刃止戈 以智御危

Agent 列表

下发命令

执行结果

全部 Flag

扫描 / RCE

日志

● Agent 列表

上次更新 17:33:01

0 在线 / 4 台

筛选

按 agent ID、IP、状态、时间过滤...

AGENT ID	连接	上报状态	主机IP	最近心跳时间	队列	心跳摘要	操作
2df803dd2412-1672	离线	idle	172.19.0.4	2026-04-16T15:47:23.5387800744+08:00 1小时前	0	{"agent_id":"2df803dd2412-1672","h...	复制 ID
2df803dd2412-1699	离线	idle	172.19.0.4	2026-04-16T15:47:34.550773304+08:00 1小时前	0	{"agent_id":"2df803dd2412-1699","h...	复制 ID
654aa4b188f8-1981	离线	idle	172.18.0.5	2026-04-16T16:29:39.596575021+08:00 1小时前	0	{"agent_id":"654aa4b188f8-1981","h...	复制 ID
654aa4b188f8-1990	离线	idle	172.18.0.5	2026-04-16T16:29:53.668666759+08:00 1小时前	0	{"agent_id":"654aa4b188f8-1990","h...	复制 ID

已扫描

RCE

Flags

列表 JSON

```
{
  {
    "target": "172.18.0.5",
    "first_seen": "2026-04-16T11:04:20.551329781+08:00",
    "last_seen": "2026-04-16T11:59:49.439664945+08:00",
    "last_reported_by_agent_id": "741c61d3b35e-32156",
    "report_count": 4
  },
  {
    "target": "http://172.18.0.1:8083",
    "first_seen": "2026-04-16T11:43:38.113662013+08:00",
    "last_seen": "2026-04-16T11:43:38.113862013+08:00",
    "last_reported_by_agent_id": "741c61d3b35e-1197",
    "report_count": 1
  },
  {
    "target": "http://172.18.0.2:8080",
    "first_seen": "2026-04-16T11:43:38.113658343+08:00",
    "last_seen": "2026-04-16T11:43:38.113658343+08:00",
    "last_reported_by_agent_id": "741c61d3b35e-1197",
    "report_count": 1
  },
  {
    "target": "ssh://172.18.0.1:22",
    "first_seen": "2026-04-16T11:43:38.113616487+08:00",
    "last_seen": "2026-04-16T11:43:38.113616487+08:00",
  }
}
```

Subagent 管理端

Bearer Token (与 -token 一致)

刷新列表

选中 agent 后自动加载最近结果；也可手动填写后点「刷新结果」。

全部 Flag (去重)

合并展示: POST /api/agent/flag 主动上报 与 POST /api/agent/logs 的 content 正则扫描 (flag{...}/flag-{...}/hws{...}/ctf{...} 等, flag/hws 与 -)。同一 flag 字符串只保留一行, 「来源」会累计多条渠道。

查看范围

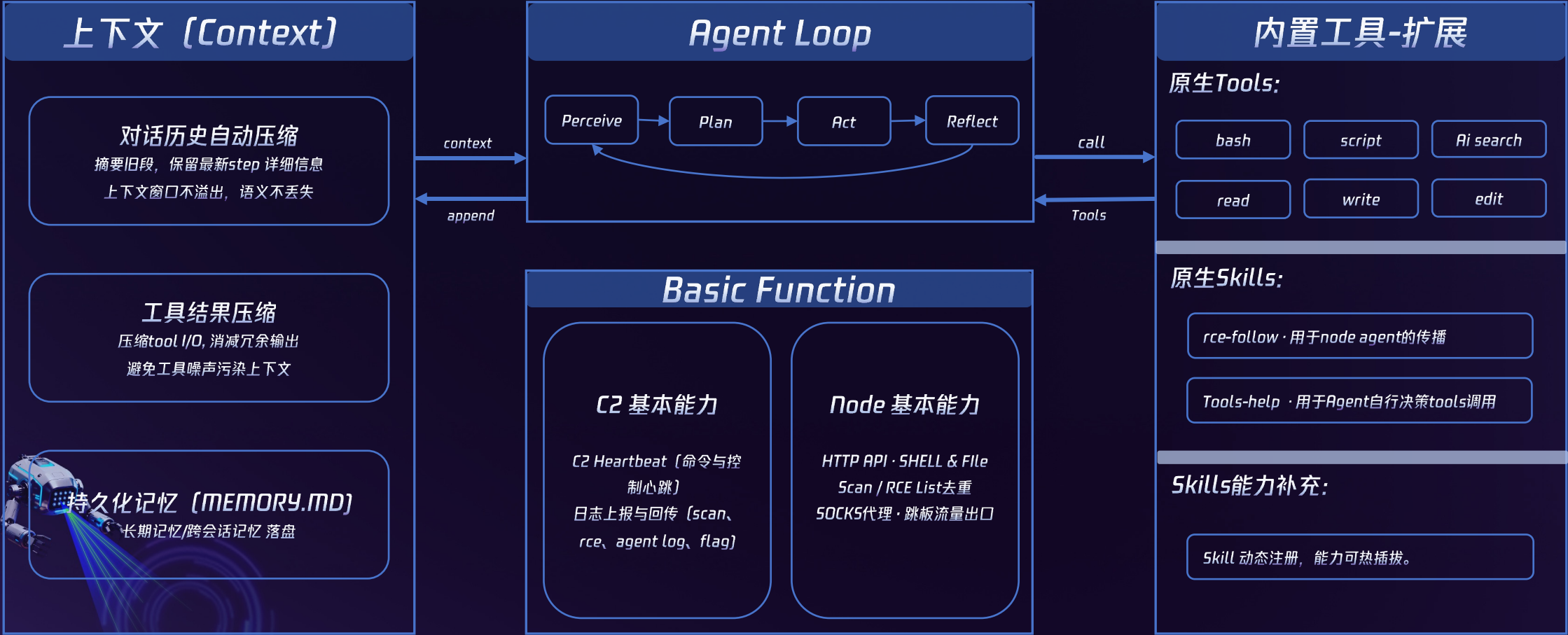
全部 (去重)

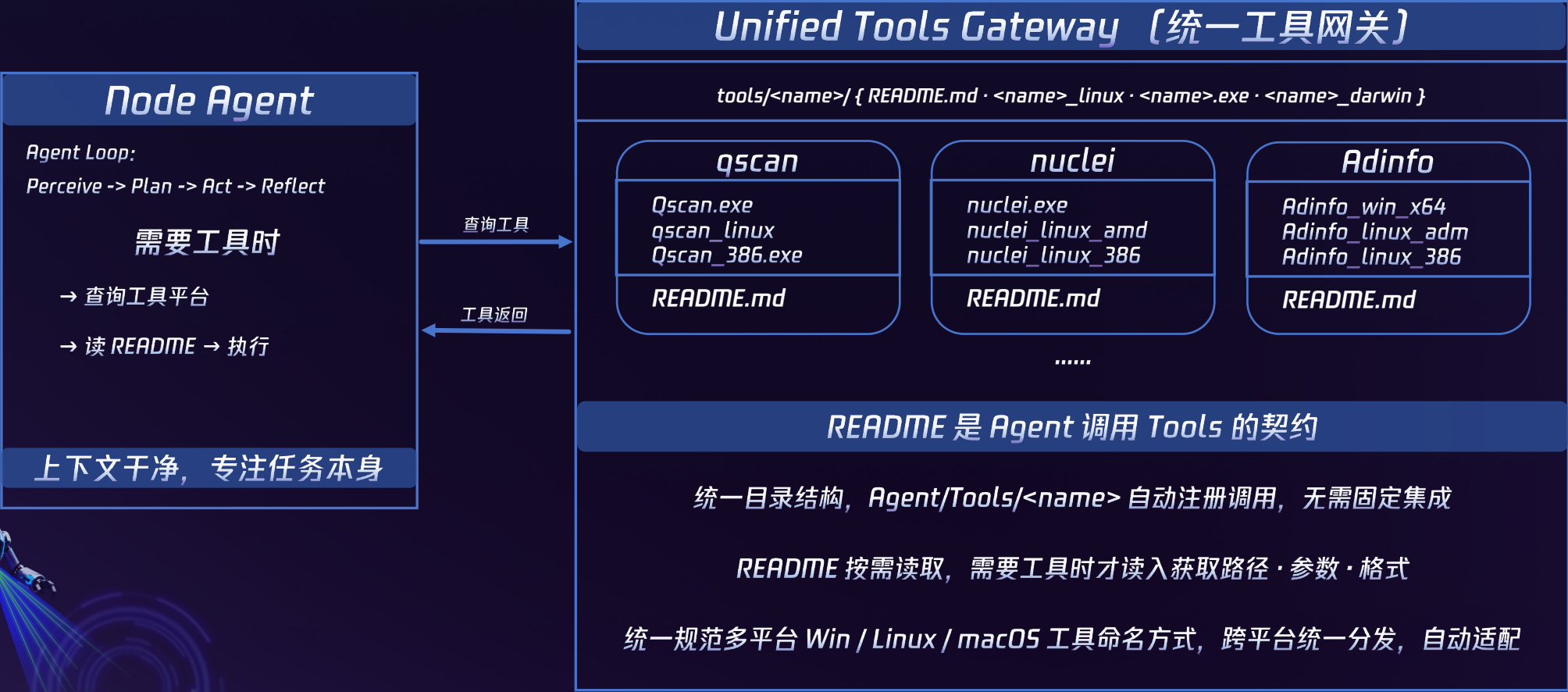
赛题正确 1 条

赛题判定正确的 Flag (data.correct === true)

flag{2a8ff91af8a2a41a081788e29a552bd5}

#	FLAG	来源	AGENT	目标	次数	首次发现	最近
1	flag{2a8ff91af8a2a41a081788e29a552bd5}	POST /api/agent/flag	2df803dd2412-1699	172.19.0.3:8080	4	2026-04-16T15:46:56.40962964+08:00	2026-04-16T15:46:59.555490931+08:00 1小时前
2	flag{253a974aa772a6d06fd11e7b62f483b8}	POST /api/agent/flag	2df803dd2412-1699	172.19.0.3:8080	4	2026-04-16T15:41:48.174445804+08:00	2026-04-16T15:41:49.551818614+08:00 1小时前
3	flag{2bc2ddce96964984bbd272a116d210e5}	POST /api/agent/flag · POST /api/agent/logs 正文扫描	654aa4b188f8-1990	main_agent_autonomous-agent.log	13	2026-04-16T14:52:14.324390299+08:00	2026-04-16T15:36:19.02991934+08:00 1小时前
4	flag{5c1fa950a4d79fd a71f93a7fc5188441}	POST /api/agent/flag · POST /api/agent/logs 正文扫描	2df803dd2412-1699	172.19.0.2:6379	21	2026-04-16T14:21:41.947479084+08:00	2026-04-16T15:14:02.41844857+08:00 2小时前
5	flag{f2efebe0081b073e89665b829c7c5454}	POST /api/agent/flag	host-1234	main_agent_autonomous-agent.log	8	2026-04-16T14:52:14.338280726+08:00	2026-04-16T15:07:01.619666141+08:00 2小时前
6	flag{22647c307a1a2f6c8fc84085938be232}	POST /api/agent/flag	host-1234	main_agent.log	4	2026-04-16T14:19:06.278093106+08:00	2026-04-16T14:19:52.298887855+08:00 3小时前





针对 Agent 的一种加强设计

Plan Resolve 编排器

Plan 阶段 · Task Planner

基于意图+配置生成最小TaskPlan
基于browser-agent 抽象场景+API

Resolve阶段 · RunPlan

基于Task Plan · 并行调度 SubAgent
动态更新 Task Plan

GlobalMemory · 全局共享记忆

业务场景 · Api接口 · Neo4j知识图谱
Key Finding · 凭据 · 漏洞

Browser

浏览器能力

页面渲染 · JS执行
XHR · Fetch 拦截
登陆态注入 · Cookie

知识图谱构建

SQLite · Neo4j
菜单场景 -> API -> 参赛
全局 Request / Response关联
接口描述 · 业务逻辑

Vuln-Test Agent · ReAct

Scenario & Idea Generator · Plan 最小化

1. Global Memory : 业务场景 · API信息 · 网站基本信息
2. 基于细颗粒度生成 三个维度的测试

Agent loop Detector

单API接口测试
Sql注入 · SSRF · 文件上传 · 命令注入
参赛篡改 · 代码执行 · 反射 XSS

Agent loop Detector

场景安全测试
登陆场景 · 支付场景 · 订单场景
注册场景 · 营销场景 · 用户管理

Agent loop Detector

全局漏洞测试
跨场景 · 多步关联 · 全局关联

Review Scenario Vuln Findings & 置信度

LLM 二次审核 + 二次验证 + 置信度打分 · 漏洞信息追加 全局 GlobalMemory

Attack Path – Web Application 图谱设计

节点类型定义

Scenario Node-业务场景

Id · {task_id}_login
Name · 场景
path_display · Login -> index
Entry · 入口 URL
Depth · 层级深度

API Node

Method · 请求方法
url / path 完整 URL · 归一化路径
source_page · 来源页
Headers · 请求头 JSON
body / status · 请求体 · 状态码
Request json · request 对象
Description · 接口描述

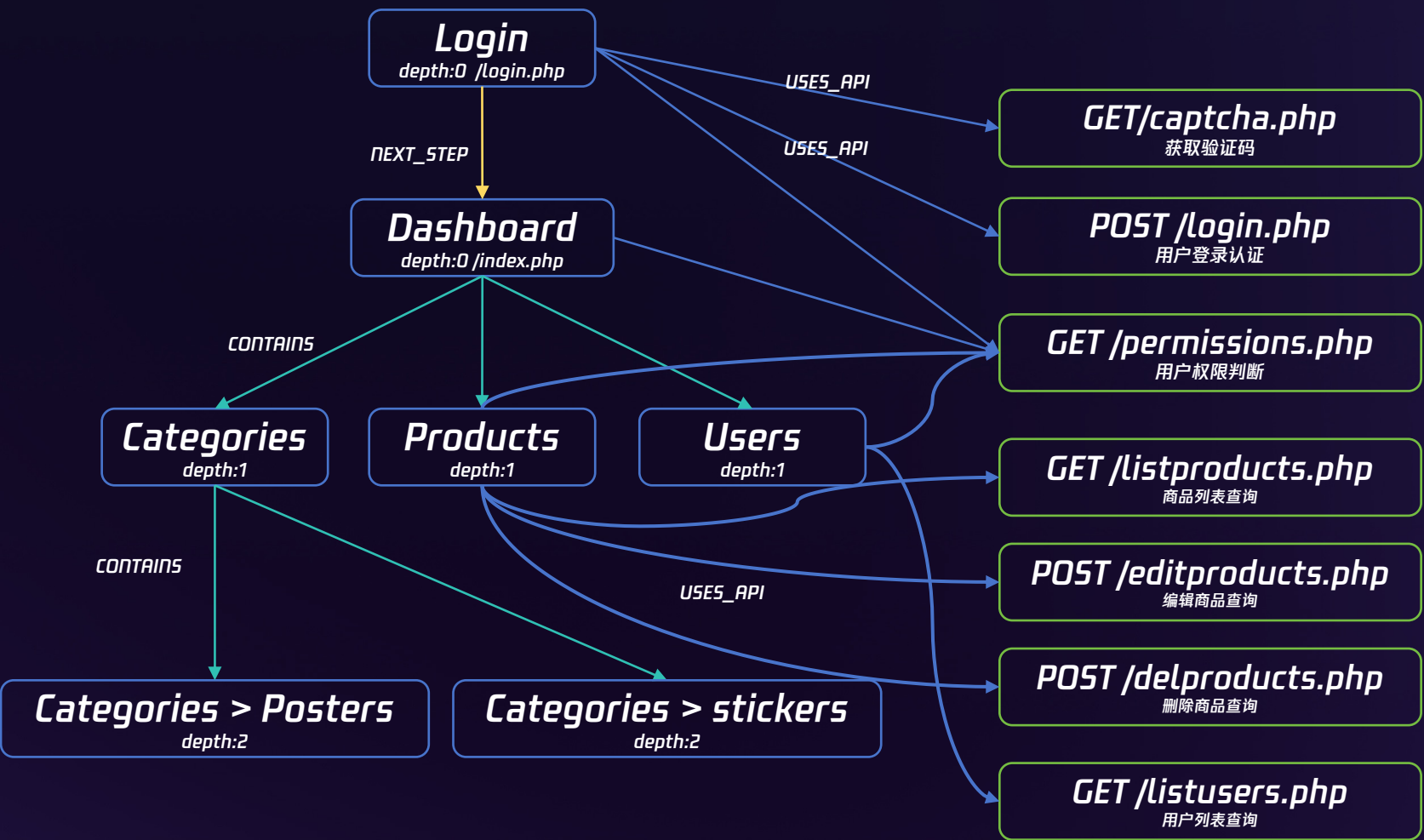


关系边定义

NEXT_STEP

CONTAINS

USES_API



Agent Security Organization 安全机制设计

执行策略

`rm -rf / · sudo · dd · shutdown · reboot` 拦截
Shell 管道、多行注入、控制字符

熔断机制

CPU / 内存 / 磁盘资源 阈值 熔断

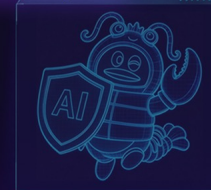
输出隔离 & 防注入

超大输出自动落盘，仅保留路径引用
落盘文件权限 `0o600`，目录 `0o700`

限制指定目录 & 内置调用约束

文件系统：路径规范化 + 符号链接检测
内置调用约束，可对内生工具进行配置





PART 03

未来展望



AI For Security

1. 攻击范式核心转变：从“人”到“智能体”

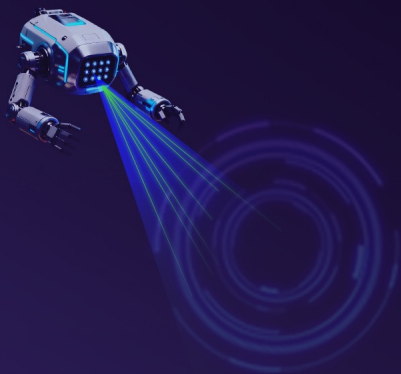
-- 攻击主体从人转变为 7×24 自主运行的 AI Agent 集群，速度、规模、持续性全面突破人类上限；

2. 新型智能对抗：AI 驱动的主动防御反制

-- 以智能对抗智能，智能蜜罐 [LLM Honeypot]、智能体反制 [Agent Counter-Agent]

Security For AI

1. AI Agent 的可信执行与运行时防护
2. AI Agent 身份与行为审计体系
3. AI-SDL：面向智能体的安全开发生命周期



THANKS

